

Güvenlik Tasarımı

Temel ilkeler

- Financial correctness, least privilege ve credential safety önceliklidir.
- Normal HTTP trafik YARP Gateway üzerinden geçer.
- Gateway auth, service/domain authorization'ın yerine geçmez.
- MSSQL durable authentication/financial source of truth'tür.
- Redis transient support state'tir.
- Production secret değerleri source control'da tutulmaz ve gerekli secret yoksa startup fail-fast olur.
- Password, OTP, JWT, refresh token, service key ve connection secret loglanmaz.
- Ownership/risk facts server-side türetilir.

Gateway trust modeli

****Client -> Gateway:**** Protected /api/* rotalarında JWT gerekir; register/verify/login/refresh anonymous'dur.

****Gateway -> FinWallet.Api:**** Gateway downstream service key taşır; API JWT ve ownership'i yeniden doğrular.

****FinWallet.Api -> Gateway /providers/*:**** InternalServiceKey gerekir.

****Gateway -> Fake provider:**** Ayrı DownstreamServiceKey gerekir.

Health route'ları orchestrator/YARP health check için açıktır; Swagger exposure environment config ile yönetilir.

HTTP attack surface

FinWallet.Shared.Web:

- Kestrel server header kapalı;
- TRACE/CONNECT blocked;
- body-bearing POST/PUT/PATCH JSON zorunlu;
- body/header count/header size limits;
- request-header/keep-alive timeout;
- max concurrent connections;
- per-IP fixed-window rate limit;
- queue default 0;
- CORS allow-list;
- bounded correlation ID;
- no-store/no-cache;
- CSP, frame/MIME/referrer/permissions/cross-origin headers.

Bu kontroller L7 abuse/resource exhaustion azaltır; volumetric DDoS için cloud/edge/ingress/WAF gerekir.

Password

V1:

- PBKDF2-HMAC-SHA512;

- 220,000 iterations;
- 32-byte random salt;
- 64-byte hash;
- constant-time comparison;
- persisted hash version.

Iteration count loose runtime tuning değildir; future change versioned migration/rehash gerektirir.

JWT ve session

JWT fixed HMAC-SHA256 kullanır; minimal sub, sid, JTI, iat claim'leri taşır. Balance/IBAN/contact içermez. Issuer/audience/signing key config/secret store'dan gelir. Lifetime güvenli bir aralıkta config edilebilir. Signing algorithm config edilemez.

High-risk transfer sid değerini MSSQL CustomerSession ile doğrular; revoke edilmiş session kısa ömürlü JWT bitmeden de para hareketini durdurabilir.

Refresh token

Opaque random token client'a verilir; raw token DB'ye yazılmaz. Rotation compare-and-set ile single-use'dur. Consumed token reuse session/token family revoke eder.

OTP

Redis'te raw OTP yerine HMAC digest tutulur. Lua script atomic issue/attempt/consume davranışı sağlar. Redis unavailable ise verification fail-closed olur.

SQL injection

Financial/auth persistence parameterized SqlCommand kullanır. Request text dynamic SQL fragment olarak kullanılmaz.

BOLA / ownership

- customer identity JWT sub'dan gelir;
- owned resource query'leri customer boundary içerir;
- transfer source ownership fraud öncesi ve locked posting içinde tekrar doğrulanır;
- destination/currency/lifecycle commit öncesi revalidate edilir.

Fraud güvenliği

Client isNewDevice, known beneficiary, velocity veya 24h amount gibi trust flag gönderemez. Bu sinyaller durable server state'ten üretilir.

```
completed replay
-> server-side risk signals
-> internal fraud
-> external fraud
-> combined decision
-> posting only on Allow
```

External fraud unavailable/malformed ise fail-closed.

Idempotency / replay

Money-changing transfer Idempotency-Key ister. Durable identity Scope + CustomerId + Key; canonical request hash same-key/different-payload kullanımını conflict yapar.

Logging

Asla loglanmaz:

- password/hash/salt;
- OTP/digest/pepper;
- JWT/refresh token;
- Authorization header;
- internal/downstream keys;
- signing key;
- credential içeren SQL/Redis connection strings;
- unmasked phone/email/IBAN/account.

OWASP/API security özeti

- Broken Access Control/BOLA: gateway+service auth, owner-aware SQL.
- Authentication failures: JWT/session/refresh rotation/login lockout/OTP/rate limit.
- Injection: parameterized SQL.
- Security Misconfiguration: prod Swagger off, bounded HTTP config, no server header.
- Cryptographic failures: PBKDF2, HMAC, short JWT, secret management.
- Sensitive business flows: durable idempotency, fraud, ledger.
- Resource consumption: rate/body/header/connection/timeouts.
- SSRF/unsafe API consumption: provider URLs server-owned config'tir.
- Supply chain: central package versions, CI build/test; SBOM/vulnerability scan halen açık iştir.

Kalan security işleri

- Gateway bypass/rate limit integration tests;
- dependency vulnerability/SBOM scanning;
- centralized masked logging/SIEM/alerting;
- NetworkPolicy/ingress/TLS hardening;
- logout/session-revoke endpoint;
- durable FraudEvents/manual review;
- incident/reconciliation runbooks.